THESSLEY

Sign in without the password.

One tap on the phone the person already holds. A key that never leaves the device. The same idea across WordPress, Linux, Windows and Active Directory.

Passkey · QR sign-in

PAM · Linux + Windows

AD · domain sign-in

Hardening · WordPress

THE PROBLEM

A shared secret is the weakest link



Passwords travel

Typed into the wrong window, reused across sites, stored where the site can read them. One leak is enough.



Phishing works

A convincing login page harvests the secret — and a second factor typed into the same page goes with it.



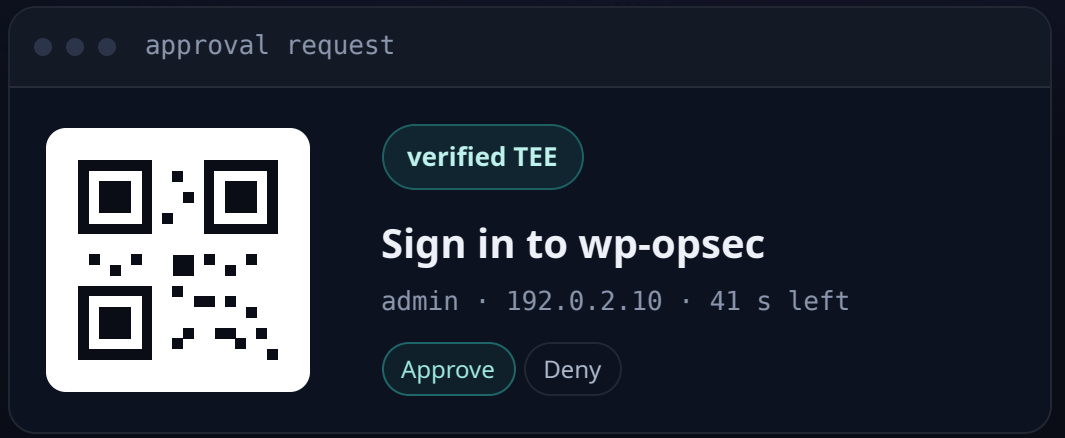
Nobody can tell you why

“Someone logged in as admin” is usually all the audit trail says. Which device, which person, approved how?

THE IDEA

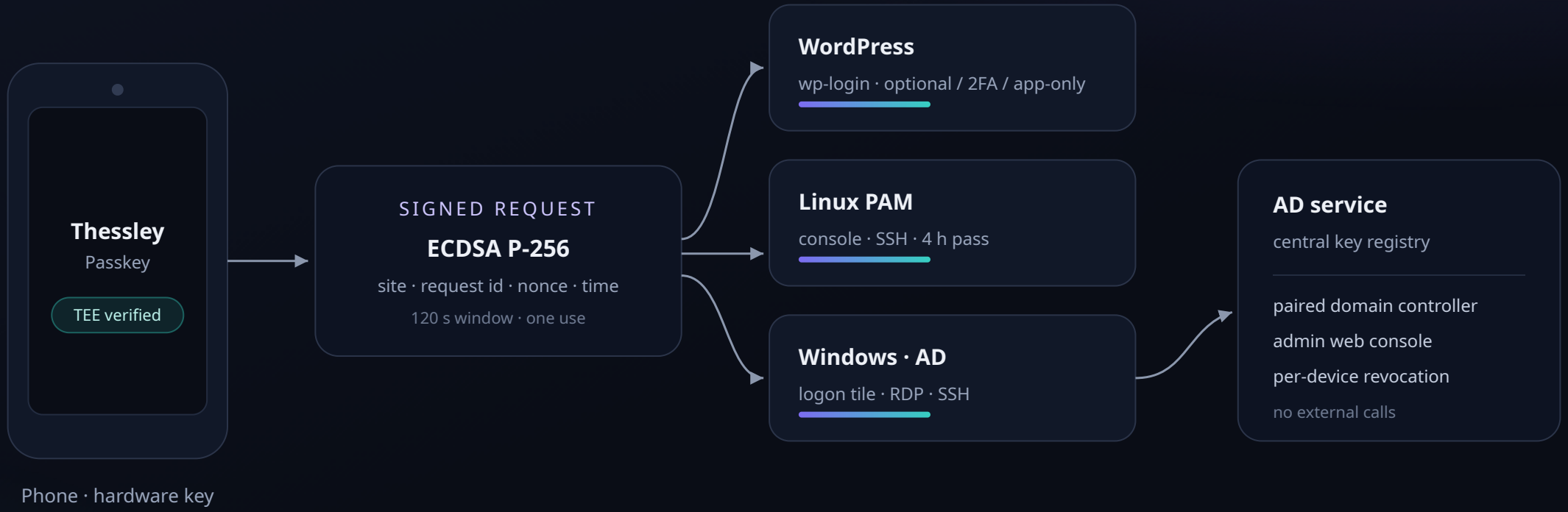
Put the key on the phone. Ask the person.

- **Possession:** an EC P-256 key generated in the phone's secure hardware.
- **Approval:** every sign-in is one visible request, confirmed with the phone's own biometric lock.
- **Origin-bound:** the signed message names the site, so a relayed QR is self-evidently for the wrong one.
- **No shared secret:** the server stores a public key, never anything that can be replayed.



ARCHITECTURE

One protocol, four front doors



same approval, every entry point

THE FLOW

Five steps, about four seconds

1

Request

The site mints a one-time request: id, nonce, origin, 120-second life.

2

Scan

The QR — or a tap on the same phone — hands the request to the app.

3

Approve

The app shows the site and account; the phone's lock authorises the signature.

4

Verify

The server checks the signature against the enrolled public key and the origin.

5

Session

The browser that started the request gets the session; the request is consumed.

120 s
request TTL

20
attempts / 10 min / IP

1×
single-use request

Only the browser that created the request can collect the session, so an approval can't be planted in someone else's browser.

SECURITY MODEL

What the server can and cannot see

On the phone

- Private key generated in Android Keystore / TPM; never exported.
- Signature requires the device lock — enforced by the key itself.
- Attestation chain proves TEE, StrongBox or TPM, where present.

On the server

- Public key, label, last-used time, attestation verdict.
- No shared secret, no password to brute-force, no replayable token.
- Origin is checked; a QR relayed from another site cannot verify.

Attested

TEE · StrongBox · TPM · software, shown honestly per device.

Bound

Signature covers site, request, nonce and time.

Throttled

Rate limits on every unauthenticated endpoint.

Revocable

One device, one account, instantly, from the profile page.

PRODUCT · WORDPRESS

Three ways to run the login page

Optional

Password or app

Password form and QR side by side. Whichever the visitor reaches for first works. Default for a soft rollout.

2FA

Password, then app

A stolen password alone is not enough; the phone confirms. The QR is not offered before the password step.

App only

Phone only

No password form for accounts with a device. Accounts without one still get the password fallback.

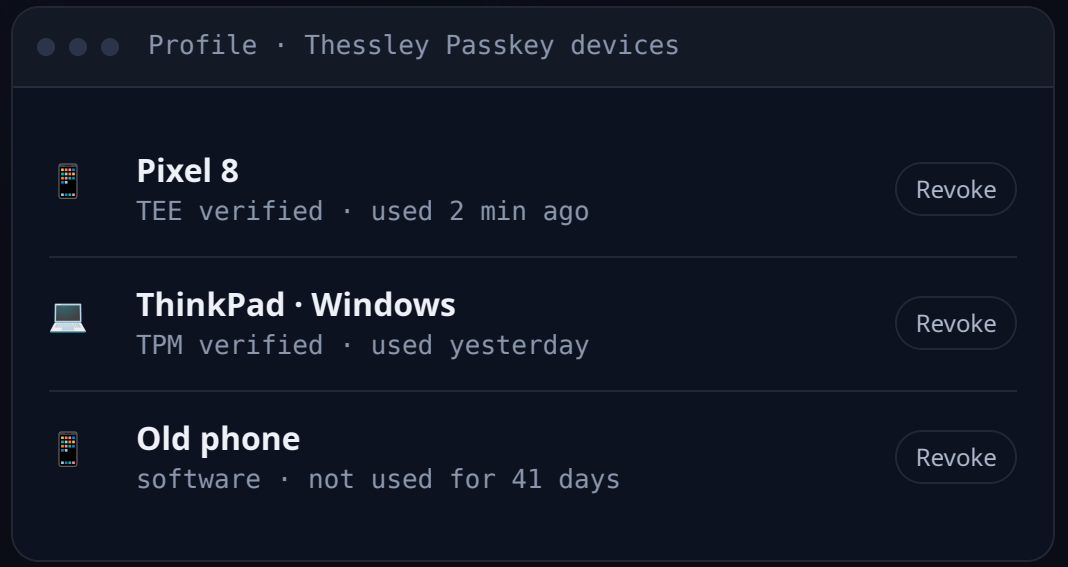
`wp-login.php → QR → approve → /wp-admin/`

same page, no redirects

PRODUCT · DEVICES

Every enrolment is a visible, revocable key

- Enrol from the profile screen — scan once, name the device, done.
- Attestation is verified server-side and shown for what it is: TEE, StrongBox, TPM, or software.
- Revoke a phone and every key it enrolled stops working immediately.
- The email notice on enrolment is the tripwire against a hijacked session adding a backdoor device.

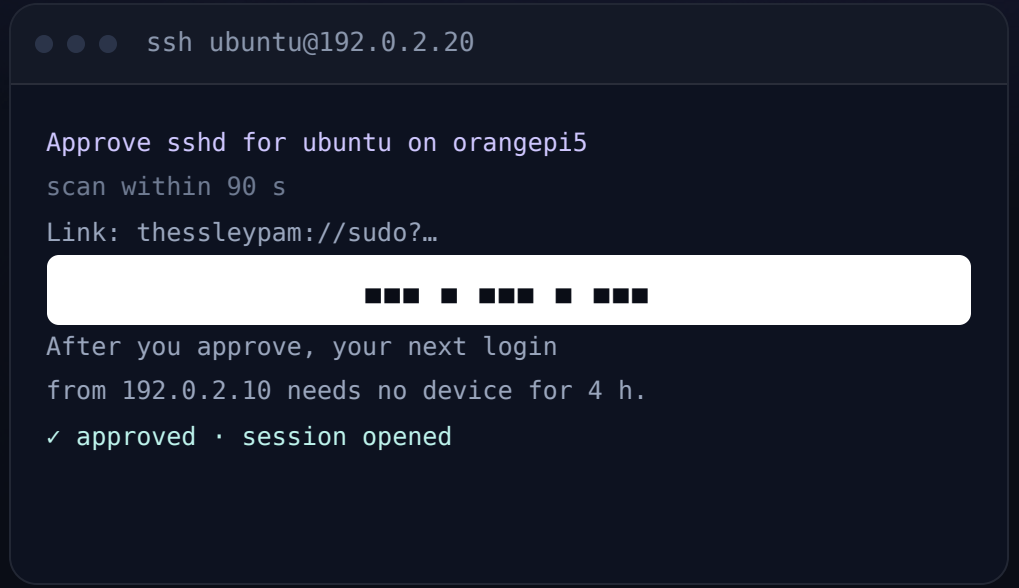


PRODUCT · LINUX

PAM: the login screen and the SSH gate

Console and SSH, same approval

- PAM module; no change to the desktop or the SSH client.
- SSH requires the key *and* the phone for the enrolled group.
- One approval covers 4 hours for that user, service and client address; then it asks again.
- Login paths are policy: key + QR, key + password recovery, or no SSH at all.



PRODUCT · WINDOWS AND ACTIVE DIRECTORY

Domain logon, RDP and SSH — admin-scoped

Logon tile

The Windows sign-in screen offers the Thessley tile; the password tile is hidden and re-asserted by policy. Domain accounts keep working.

RDP

NLA off so the connection lands on the tile, always prompt, and only Administrators may connect at all.

Gate

SSH is administrator-only and every login needs the key plus the phone. Logon rights are written and verified, not just suggested.

1
tile on the lock screen

4 h
pass per user · service · IP

0
password tiles left

22
devices on the lab DC

The domain controller keeps the central registry: pair a PC once, and its users sign in with the phone that already holds their key.

PRODUCT · HARDENING

Every module, one Event Log

IP blocklist
Public feeds + local escalations

Geo blocker
Country allow/block

Geo login
wp-login by country

Rate limiter
Per-IP throttling

Query guard
SQLi, XSS, traversal

Login guard
Failed-login lockout

File integrity
Core + baseline

Malware scan
Webshell signatures

Vulnerability scan
Outdated components

Auto updates
Flagged-only mode

User watchdog
Hidden admins

Hardening
Post-compromise tools

Headers
Browser-side

Alerts
Telegram + email

Event log
Everything, severity 1–20

Activity · bots
Audit + crawler log

Plugin Check `0 errors · 0 warnings` Each module can be log-only or enforcing, on its own.

OPERATIONS

Boring to deploy, easy to undo

One command

The Windows installer detects a paired PC, installs the tile, hides the password provider, gates SSH, sets RDP and logon rights — and can keep every change instead of timing out.

```
guided-install.ps1 -Unattended -ServerUrl … -PairingCode …
```

Reversible by default

Every hardening step saves its previous state and can arm a timed rollback; the installer passes `-Keep` only when you mean it.

```
-Keep · -SignInGroup "Thessley Sign-in"
```

Tested, not assumed

Behavioural suites, HTTP end-to-end, real EC signatures, and Plugin Check in CI-shaped runs. Compatibility: WordPress 6.0+, PHP 8.3.

Self-hosted

No external service, no telemetry, no phone-home. QR codes are generated locally; keys and audit data stay on your infrastructure.

THESSLEY

Passwords out. Possession in.

The same key on the phone signs in to WordPress, Linux, Windows and the domain. One approval, one audit trail, nothing reusable left behind.

thessley-passkey · WordPress

thessley-pam · Linux

thessley-passkey-linux · Windows/Linux desktop

AD service · Active Directory